

Purple Teaming в белорусских реалиях: как совместная работа Red Team и Blue Team помогает пройти аттестацию ОАЦ

 redsec.by/article/purple-teaming-v-belorusskih-realiyah-kak-sovmestnaya-rabota-red-team-i-blue-team-pomogaet-projti-attestaciju-oac

Red Teams | 27 октября 2025



Зачем Purple Team нужен белорусским организациям

В условиях постоянно растущих киберугроз и ужесточения требований Оперативно-аналитического центра при Президенте Республики Беларусь (ОАЦ) к защите информации, организации сталкиваются с необходимостью не просто внедрять дорогостоящие средства защиты, но и доказывать их реальную эффективность. Аттестация системы защиты информации — это не формальность, а обязательное требование для многих компаний, которое требует подтверждения соответствия

законодательству Республики Беларусь. Это, в свою очередь, означает демонстрацию зрелого и проактивного подхода к обеспечению информационной безопасности.

Классическая модель противостояния, где "красная" команда (Red Team) имитирует атаки, а "синяя" (Blue Team) пытается их обнаружить и отразить, часто работает в отрыве друг от друга. Это приводит к созданию атмосферы соревнования, а не сотрудничества, где отчеты Red Team ложатся на полку, а Blue Team продолжает работать в условиях "информационного голода". **Purple Teaming** кардинально меняет эту парадигму. Это не отдельная команда, а философия совместной работы, где атакующие и защитники действуют сообща, обмениваясь знаниями в режиме реального времени для непрерывного улучшения процессов мониторинга, реагирования и общей защищенности организации.

Для белорусских организаций, стремящихся соответствовать высоким стандартам регулятора, Purple Teaming становится критически важным инструментом, который позволяет:

- **Объективно подтвердить готовность к прохождению аттестации ОАЦ.** Вместо теоретических выкладок и отчетов о настройке СЗИ, вы предоставляете конкретные доказательства способности обнаруживать и блокировать реальные, актуальные для вашей отрасли атаки.
- **Значительно улучшить процессы мониторинга и реагирования.** В ходе совместной работы SIEM-система обогащается новыми, кастомизированными правилами корреляции, которые отлажены на реальных сценариях атак, а не на базовых шаблонах.
- **Повысить квалификацию команды ИБ.** Purple Teaming — это интенсивный практический тренинг на вашей реальной инфраструктуре. Аналитики SOC учатся распознавать сложные атаки, а атакующие специалисты лучше понимают возможности систем защиты.
- **Выявить критические пробелы в защите до того, как их обнаружит регулятор или реальный злоумышленник.** Это проактивный подход, позволяющий устранить уязвимости до наступления катастрофических последствий.

Таким образом, внедрение практик Purple Teaming — это стратегический шаг от формального соответствия требованиям к построению реально работающей, киберустойчивой системы защиты информации.

Что такое Purple Teaming: концепция совместной работы

Purple Teaming — это методология и функция в кибербезопасности, объединяющая экспертизу, инструменты и навыки специалистов по атаке (Red Team) и защите (Blue

Team) для итеративного улучшения безопасности организации. Термин «Purple» (фиолетовый) символизирует смешение красного (атака) и синего (защита) цветов, подчеркивая синергию и коллаборацию.

Ключевые отличия от классических Red Team операций:

- **Red Team** работает максимально скрытно, имитируя действия реальных злоумышленников (APT-группировок). Их главная цель — проникнуть в инфраструктуру как можно глубже и незаметнее, чтобы проверить, сможет ли команда защиты (Blue Team) самостоятельно обнаружить и остановить атаку. Blue Team, как правило, не предупреждают о начале учений.
- **Purple Team**, напротив, действует открыто и совместно. Red Team заранее уведомляет Blue Team о планируемых атаках, их целях, используемых тактиках, техниках и процедурах (TTPs). Основная цель — не "победить" защитников, а вместе с ними в режиме реального времени проверить, как системы мониторинга и реагирования справляются с конкретной угрозой.

Философия Purple Teaming строится на следующих принципах:

- **Информационный обмен, а не противостояние.** Команды делятся друг с другом информацией: атакующие объясняют, какие шаги они предпринимают, а защитники показывают, какие события и алерты они видят (или не видят) в своих системах.
- **Взаимное обучение.** Red Team демонстрирует новые и нестандартные векторы атак, обогащая знания Blue Team. В свою очередь, Blue Team показывает, какие артефакты оставляет атака в логах, какие техники легко обнаруживаются, а какие остаются "слепыми пятнами", что дает атакующим пищу для размышлений о новых методах обхода защиты.
- **Итеративное улучшение.** Цикл "атака → совместный анализ → усиление защиты → повторная атака" является ядром методологии. Это позволяет не просто найти уязвимость, а убедиться, что принятые меры по ее устранению действительно работают.
- **Фокус на конкретных угрозах и сегментах.** Учения могут быть сосредоточены на проверке защиты конкретных сегментов инфраструктуры (например, облачные узлы, ключевые серверы, DMZ) или на отработке сценариев противодействия конкретным APT-группировкам, актуальным для отрасли.

По сути, Purple Teaming — это контролируемый спарринг, где задача тренера (Red Team) — не нокаутировать ученика (Blue Team), а помочь ему отточить технику и подготовиться к реальному поединку.

Как Purple Team работает на практике: пошаговый цикл

Типичный цикл Purple Teaming — это структурированный процесс, который можно адаптировать под нужды любой организации. Он включает в себя несколько последовательных этапов.

1. Оценка угроз и планирование

На этом этапе закладывается фундамент будущих учений. Команды совместно определяют цели, область тестирования и наиболее вероятные угрозы.

- **Blue Team** проводит экспресс-аудит текущих настроек правил обнаружения в SIEM и других системах мониторинга. Это помогает понять, какие атаки теоретически должны быть обнаружены, а где существуют явные пробелы.
- **Red Team** составляет профиль потенциального злоумышленника, определяет вероятные точки входа и слабые места в системе защиты.
- **Совместная работа:** В белорусских реалиях на этом этапе критически важно сформировать **модель угроз** с учетом требований **ОАЦ РБ** и, при необходимости, **ФСТЭК**. Проводится категоризация информационных систем по классам защиты (например, 3-ин, 3-спец, 3-юл). На основе данных киберразведки (Cyber Threat Intelligence) выбираются наиболее актуальные для отрасли (финансовый сектор, промышленность, госуправление) сценарии атак.

2. Подготовка и согласование сценариев

На основе модели угроз разрабатываются и детально согласовываются конкретные сценарии атак (тест-кейсы). В качестве основы для классификации техник атак используется общепринятая матрица **MITRE ATT&CK®**.

Примеры согласованных сценариев:

- **Credential Access (Получение учетных данных):** Атака **Kerberoasting** для извлечения хешей паролей сервисных учетных записей.
- **Lateral Movement (Продвижение по сети):** Использование техники **Pass-the-Hash** для перемещения между серверами без знания пароля в открытом виде.
- **Privilege Escalation (Повышение привилегий):** Атака **DCSync** для получения учетных данных всех пользователей домена.
- **Persistence (Закрепление в системе):** Создание **Golden Ticket** для получения долгосрочного и неограниченного доступа к домену.

На этом этапе подписываются все необходимые соглашения, определяются рамки и ограничения (Rules of Engagement), а Red Team предоставляются необходимые доступы (например, учетная запись с правами обычного пользователя для начала атаки изнутри).

3. Проведение атаки (Execution)

Это самая динамичная фаза. Red Team запускает согласованную цепочку атак, meticulously документируя каждое свое действие с точными временными метками (timestamp). Эта документация включает:

- Время запуска инструментов (например, Mimikatz, Rubeus).
- Используемые команды и их параметры.
- IP-адреса источника и цели.
- Полученные результаты (например, скомпрометированные учетные записи, извлеченные хеши).

В это же время **Blue Team** активно наблюдает за своими системами мониторинга (SIEM, EDR, IDS/IPS, межсетевые экраны), пытаясь обнаружить аномальную активность. Анализ может проводиться как в режиме реального времени, так и ретроспективно, когда защитники сопоставляют свои журналы событий с таймлайном, предоставленным атакующими.

4. Анализ и оценка работы SOC (Security Operations Center)

Сразу после каждого этапа атаки (или в конце всего сценария) команды проводят совместный разбор полетов. Это ключевой момент всего процесса.

Обсуждаются следующие вопросы:

- **Что обнаружила Blue Team?** Какие события были зафиксированы в SIEM? Какие правила корреляции сработали и сгенерировали алерты?
- **Что было пропущено?** Какие действия Red Team остались незамеченными и, что самое главное, почему? Недостаточное логирование? Отсутствие нужного правила? Неверная конфигурация СЗИ?
- **Как можно улучшить детектирование?** Команды совместно вырабатывают конкретные рекомендации.

Результатом этого этапа является перечень конкретных задач по улучшению:

- Создание новых правил корреляции в SIEM.
- Настройка дополнительного или более детального логирования на конечных точках и серверах.
- Изменение конфигурации средств защиты (например, блокировка определенных протоколов).
- Обновление плейбуков (инструкций) по реагированию на инциденты.

5. Митигация и повторное тестирование

На этом этапе Blue Team внедряет согласованные улучшения. После того как новые правила созданы, логирование настроено, а процессы обновлены, Red Team проводит повторную атаку, используя тот же сценарий. Цель — проверить, насколько эффективными оказались принятые меры. Цикл повторяется до тех пор, пока не будет достигнут желаемый уровень защищенности и скорость обнаружения угрозы.

Практический пример 1: Обнаружение атаки Kerberoasting

Рассмотрим детально, как цикл Purple Teaming работает на примере **Kerberoasting** — одной из самых распространенных и опасных техник компрометации Active Directory.

Суть атаки Kerberoasting: Злоумышленник, имея доступ к любой учетной записи в домене, может запрашивать у контроллера домена специальные билеты (TGS) для сервисных учетных записей (те, у которых настроен Service Principal Name, SPN). В этих билетах содержится часть, зашифрованная хешем пароля сервисной учетной записи. Атакующий извлекает эти билеты и пытается подобрать пароль в офлайн-режиме, не взаимодействуя больше с инфраструктурой жертвы. Если пароль сервисной учетной записи слабый, его можно быстро взломать.

Сценарий Purple Team

Подготовка (Red Team): Red Team уведомляет Blue Team, что в определенное время (например, в 14:00) будет проведена атака Kerberoasting с рабочей станции пользователя user_test. Будут использованы инструменты Rubeus (для Windows) или GetUserSPNs.py из пакета Impacket (для Linux).

Действия (14:00 - 14:05):

Red Team запускает Rubeus. В журналах безопасности Windows на контроллере домена начинают генерироваться события **Event ID 4769 (A Kerberos service ticket was requested)**. При атаке Kerberoasting эти события имеют характерные аномалии:

- **Ticket Encryption Type: 0x17 (RC4-HMAC)** — это устаревший и слабый алгоритм шифрования, который часто используют инструменты для атаки.
- **Ticket Options: 0x40800000** — нестандартные опции, используемые Rubeus по умолчанию.
- **Аномальное количество запросов:** Одна учетная запись за короткий промежуток времени (несколько секунд) запрашивает десятки TGS-билетов для разных сервисов.

Обнаружение (Blue Team в реальном времени):

Аналитик SOC видит в SIEM всплеск событий с Event ID 4769 от пользователя

user_test, но автоматического алерта нет. Существующие правила корреляции не настроены на выявление таких аномалий. Аналитик вручную замечает, что все запросы используют слабый тип шифрования и направлены к учетным записям пользователей, а не компьютеров (имена сервисов не заканчиваются на \$).

Проблема: атака видна в "сырых" логах, но система мониторинга на нее не реагирует.

Расследование (совместный анализ): После 14:05 Red Team предоставляет Blue Team полный таймлайн своих действий. Blue Team сопоставляет его со своими логами и подтверждает, что события 4769 точно совпадают по времени и источнику. Становится очевидно, что в SIEM отсутствует необходимое правило детектирования.

Митигация и улучшение: Совместными усилиями команды создают новое правило корреляции в SIEM:

ПРАВИЛО: "Обнаружение Kerberoasting"

Условия:

- Event ID = 4769 (Запрошен билет службы Kerberos)
- Количество событий ≥ 10 за 60 секунд от одного пользователя
- И Ticket Encryption Type = 0x17 (RC4-HMAC)
- И Service Name НЕ заканчивается на "\$"
- Исключить системные учетные записи (например, KRBTGT)

Действия:

- Создать инцидент высокого приоритета (High Severity)
- Уведомить аналитика SOC

Дополнительные меры:

- Включение расширенного аудита Kerberos на контроллерах домена.
- Внедрение политики использования сложных, длинных паролей для всех сервисных учетных записей.
- Создание "honeypot" — фейковой сервисной учетной записи с очень сложным паролем, обращение к которой будет немедленно сигнализировать об атаке.

Повторное тестирование:

На следующий день Red Team запускает атаку снова. В этот раз SIEM генерирует алерт через 30-40 секунд после начала атаки. Blue Team получает уведомление и немедленно начинает расследование по утвержденному плейбуку.

Результат: Время обнаружения атаки сократилось с "бесконечности" до менее чем одной минуты. Создано эффективное правило, которое будет защищать организацию от реальных атак.

Практический пример 2: Продвижение по сети через Pass-the-Hash

Другой классический сценарий — перемещение по сети после компрометации одной рабочей станции.

Суть атаки Pass-the-Hash:

Злоумышленник, получив NTLM-хеш пароля пользователя (например, администратора) из памяти процесса LSASS с помощью инструмента **Mimikatz**, может использовать этот хеш для аутентификации на других машинах в сети, не зная самого пароля в открытом виде.

Сценарий Purple Team

Действия (Red Team):Получив доступ к рабочей станции, Red Team запускает Mimikatz и извлекает хеш пароля доменного администратора. Затем, используя этот хеш, они подключаются к файловому серверу с помощью утилиты psexec.py.

Обнаружение (Blue Team):Индикаторы компрометации (IoCs) появляются в разных местах:

- **На скомпрометированной рабочей станции:**
 - **Event ID 4688 (Создан новый процесс):** запуск mimikatz.exe.
 - **Sysmon Event ID 10 (Process Access):** зафиксирован доступ к памяти процесса lsass.exe.
- **На целевом файловом сервере:**
 - **Event ID 4624 (Успешный вход в систему):**
 - **Logon Type: 3 (Network)** — сетевой вход.
 - **Authentication Package: NTLM** (вместо более современного и безопасного Kerberos).
 - **Source Network Address:** IP-адрес скомпрометированной рабочей станции.
 - **Event ID 4672 (Специальные привилегии назначены новому сеансу входа):** вход с административными правами.

Аномалии для корреляции:

- Вход на сервер с правами администратора с обычной рабочей станции — это подозрительно.
- Использование NTLM-аутентификации вместо Kerberos в современной доменной инфраструктуре — явный "красный флаг".
- Короткий временной промежуток между запуском Mimikatz на одной машине и успешным административным входом с нее на другую.

Митигация и улучшение (Blue Team): На основе этих индикаторов создается новое правило корреляции:

ПРАВИЛО: "Обнаружение Lateral Movement с использованием Pass-the-Hash"

Условия:

- Event ID 4624 (Успешный вход)
- И Logon Type = 3 (Network)
- И Authentication Package = NTLM
- И Source IP находится в подсети рабочих станций
- И Target IP является критичным сервером (DC, файловый сервер)
- И (Опционально) За последние 10 минут на Source IP было событие Sysmon Event ID

Действия:

- Создать инцидент критического уровня (Critical)
- Уведомить старшего аналитика SOC
- Изолировать Source IP от сети

Итерации улучшения:

После первого теста Blue Team дополнительно включает **Sysmon** на всех рабочих станциях и настраивает **Windows Credential Guard** для защиты учетных данных в памяти. Red Team в следующий раз пытается использовать более продвинутые техники обхода. Цикл Purple Teaming продолжается, повышая планку защищенности.

Ценность Purple Teaming для аттестации ОАЦ

Для белорусских организаций прохождение аттестации системы защиты информации является обязательным условием для работы с определенными видами данных.

Purple Teaming становится мощным инструментом для подготовки и успешного прохождения этой процедуры.

1. Документальное подтверждение эффективности СЗИ

Аттестация требует не просто наличия СЗИ, а подтверждения их правильной настройки и эффективности. Purple Team генерирует объективные доказательства, которые можно и нужно предоставлять аттестующей организации:

- **Отчеты о проведенных киберучениях** с подробным описанием смоделированных TTPs злоумышленников.
- **Метрики эффективности SOC:** Процент успешно обнаруженных атак, среднее время до обнаружения (Time to Detect) и время до реагирования (Time to Respond).
- **Журналы улучшений:** Перечень созданных правил корреляции, отчеты об изменении настроек СЗИ, обновленные плейбуки реагирования.
- **Доказательства работоспособности процессов:** Скриншоты алертов из SIEM, тикеты в системе управления инцидентами, таймлайны расследований.

Эти артефакты служат неопровержимым доказательством зрелого подхода к ИБ и практической реализации требований законодательства.

2. Обогащение SIEM релевантными правилами корреляции

Многие организации используют SIEM-системы с базовым набором правил, которые не учитывают специфику их инфраструктуры. Purple Team позволяет решить эту проблему:

- Создаются **кастомизированные правила**, нацеленные на обнаружение угроз, актуальных именно для вашей компании и отрасли.
- Устраняются **ложноположительные срабатывания (False Positives)**, так как каждое правило тестируется и отлаживается в ходе учений.
- Повышается **покрытие техник из матрицы MITRE ATT&CK**, что позволяет системно подходить к обнаружению сложных многоэтапных атак.

Метрика	До Purple Team	После 6 месяцев Purple Team
Количество кастомных правил	15 (базовые)	52 (+37 высокоэффективных)
Покрытие MITRE ATT&CK	45% техник	78% техник
Ложноположительные срабатывания	35% от всех алертов	12% от всех алертов
Время обнаружения критичных атак	Не обнаружено / часы	< 5 минут

3. Повышение квалификации и готовности команды ИБ

Аттестация также оценивает компетентность персонала. Purple Team — это лучший способ практической подготовки:

- **Blue Team** видит вживую, как выглядят атаки, о которых они читали в теории. Это бесценный опыт, который невозможно получить из книг.
- **Red Team** лучше понимает, какие техники легко обнаруживаются современными СЗИ, а какие остаются "невидимыми", что позволяет им фокусироваться на более сложных векторах.
- Формируется **единое понимание ландшафта угроз** и методов защиты, разрушаются барьеры между разными подразделениями ИБ.

4. Проактивное выявление пробелов в защите

Purple Team позволяет обнаружить и устранить критические недостатки до того, как их найдут реальные злоумышленники или проверяющие от ОАЦ. Типичные находки в белорусских организациях включают:

- Отсутствие мониторинга ключевых событий безопасности на контроллерах домена (4768, 4769, 4771, 4625).
- Неправильная настройка сбора логов (Windows Event Forwarding), приводящая к их потере.
- Сервисные учетные записи со слабыми, никогда не меняющимися паролями.
- Отсутствие сегментации сети, что позволяет атакующему беспрепятственно перемещаться по всей инфраструктуре.
- Некорректные права доступа к объектам Active Directory, открывающие путь к атакам типа DCSync.

Устранение этих проблем до официальной проверки значительно повышает шансы на успешное и безболезненное прохождение аттестации.

Матрица зрелости ИБ: как Purple Team ускоряет рост

Purple Teaming помогает организации быстрее продвигаться по уровням модели зрелости кибербезопасности. Для успешной аттестации необходимо находиться как минимум на "Определенном" уровне.

Уровень	Характеристика	Без Purple Team	С Purple Team
1. Начальный	ИБ реализована точно, процессы отсутствуют.	Базовые СЗИ установлены, но их эффективность не проверена.	-
2. Воспроизводимый	Процессы есть, но не формализованы.	SOC реагирует на базовые алерты, но реакция хаотична.	Purple Team выявляет "слепые зоны" в мониторинге.
3. Определенный	Процессы документированы и стандартизированы.	Есть плейбуки реагирования, SIEM настроен.	Purple Team валидирует плейбуки, создает кастомные правила, доказывает работоспособность процессов.
4. Управляемый	Эффективность процессов измеряется (KPI, метрики).	Ведутся метрики эффективности SOC (TTD, TTR).	Purple Team регулярно тестирует защиту, метрики постоянно улучшаются.
5. Оптимизируемый	Непрерывное совершенствование и автоматизация.	Проактивный поиск угроз (Threat Hunting), автоматизация реагирования (SOAR).	Purple Team интегрирован в цикл CI/CD безопасности, тестируя новые угрозы.

Организация Purple Team в белорусских условиях

Внутренняя команда vs. Внешний подрядчик

- **Внутренняя Purple Team:**
 - **Преимущества:** Глубокое знание своей инфраструктуры, возможность проводить учения регулярно и без дополнительных затрат.
 - **Недостатки:** Требуется наличия в штате высококвалифицированных специалистов по атаке и защите, что сложно для небольших компаний. Есть риск "замыливания" взгляда.
- **Внешний подрядчик:**
 - **Преимущества:** Профессионалы с огромным опытом, свежий взгляд на систему защиты, использование новейших TTPs. Отчеты от авторитетного подрядчика имеют большой вес при аттестации.
 - **Недостатки:** Высокая стоимость, учения проводятся реже, требуется время на погружение подрядчика в специфику инфраструктуры.
- **Гибридный подход (рекомендуется):**
 - **Внутренняя команда** проводит регулярные (ежемесячные/ежеквартальные) учения по базовым и наиболее критичным сценариям.
 - **Внешний подрядчик** привлекается 1-2 раза в год для проведения комплексного тестирования с использованием продвинутых техник, а также непосредственно перед аттестацией для финальной валидации.

Интеграция Purple Team с циклом аттестации ОАЦ

Процесс подготовки к аттестации можно и нужно синхронизировать с учениями Purple Team.

- **Этап 1: Предварительная оценка (за 6-9 месяцев до аттестации).** Проведение первого комплексного учения для оценки текущего состояния (baseline). Формирование дорожной карты улучшений.
- **Этап 2: Итеративное улучшение (за 3-6 месяцев до аттестации).** Регулярные сессии по конкретным сценариям, создание и отладка правил, обучение персонала, документирование всех изменений.
- **Этап 3: Финальная валидация (за 1-2 месяца до аттестации).** Проведение масштабного учения (возможно, с привлечением внешнего подрядчика) для проверки всех критичных контролей. Подготовка итоговой отчетности для ОАЦ.
- **Этап 4: Поддержка после аттестации.** Регулярные учения для поддержания высокого уровня защищенности и подготовки к следующей ре-аттестации.

Практические рекомендации по внедрению

С чего начать:

- **Оцените текущую зрелость.** Если у вас нет централизованного сбора логов и SIEM-системы, начните с этого.
- **Определите критичные активы** и наиболее вероятные угрозы для вашей отрасли.
- **Начните с малого.** Выберите 5-10 наиболее распространенных техник из MITRE ATT&CK и сфокусируйтесь на них.
- **Обеспечьте базовое логирование.** Убедитесь, что с контроллеров домена и ключевых серверов собираются необходимые события безопасности.

Типовые сценарии для первых учений:

- **Credential Access:** Kerberoasting (T1558.003), LSASS memory dumping (T1003.001).
- **Lateral Movement:** Pass-the-Hash (T1550.002), RDP/SMB с украденными учетными данными.
- **Persistence:** Golden Ticket (T1558.001), Scheduled Tasks.

Зрелый подход к ИБ через Purple Team

Purple Teaming трансформирует информационную безопасность из реактивной функции в проактивную, управляемую стратегию. Для белорусских организаций, готовящихся к аттестации ОАЦ, это не просто "модная" практика, а критически важный инструмент для достижения реальной, а не бумажной безопасности.

Ключевые выводы:

- **Purple Team — это не команда, а функция совместной работы Red и Blue Team.**
- **Итеративность — основа успеха: атака → анализ → улучшение → повторная атака.**
- **Фокус на практике:** реальные атаки на реальной инфраструктуре дают объективную картину защищенности.
- **Документирование критически важно:** каждое улучшение должно быть зафиксировано для предоставления аттестационной комиссии.
- **Регулярность обеспечивает зрелость:** разовое тестирование не даст устойчивого результата.

Организации, внедрившие Purple Teaming, демонстрируют высший уровень зрелости своего подхода к информационной безопасности. Они не просто устанавливают средства защиты, а постоянно проверяют их эффективность против реальных, современных угроз. Это именно то, что ожидают увидеть регуляторы при аттестации системы защиты информации в Республике Беларусь. Начните с малого, и каждая итерация будет приближать вас к цели — созданию по-настоящему киберустойчивой инфраструктуры.

